

## Encuesta FAIR-STRIDE para organizaciones

### 1. Información general de la organización

1.1 Tipo de organización (seleccione la opción que mejor la describa).

- ☐ Administración pública general
- ☐ Administración autonómica o local
- ☐ Entidad financiera (banca, seguros, medios de pago)
- ☐ Operador de servicios esenciales (energía, agua, transporte, salud)
- ☐ Proveedor TIC / nube / telecomunicaciones
- ☐ Industria / manufactura
- ☐ Servicios profesionales (consultoría, legal, auditoría, etc.)
- ☐ PyME multisectorial
- ☐ Otro (especifique): \_\_\_\_

1.2 Tamaño aproximado de la organización (empleados).

- ☐ Menos de 50
- ☐ 50 – 249
- ☐ 250 – 999
- ☐ 1.000 – 4.999
- ☐ 5.000 – 19.999
- ☐ 20.000 o más

1.3 Ámbito territorial principal de operaciones.

- ☐ Local / regional
- ☐ Nacional (España)
- ☐ Unión Europea
- ☐ Internacional (fuera de la UE)

1.4 ¿Cuál es su función principal en la organización?

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CIO / CTO / Responsable de TI
- ☐ Responsable de Riesgos / Cumplimiento / Auditoría
- ☐ Dirección de Negocio / Unidad de línea
- ☐ Otro (especifique): \_\_\_\_

### 2. Enfoque general de gestión de riesgos de ciberseguridad

2.1 ¿Dispone la organización de un marco formal de gestión de riesgos de ciberseguridad documentado y aprobado?

- ☐ Sí, alineado con ISO 27001 / 27005
- ☐ Sí, alineado con NIST (CSF, RMF u otros)
- ☐ Sí, otro marco formal (indique): \_\_\_\_

- ☐ No, pero estamos en proceso de definirlo
- ☐ No, y no está previsto en el corto plazo

## 2.2 ¿Con qué frecuencia se realiza una evaluación formal de riesgos de ciberseguridad?

- ☐ Al menos una vez al año
- ☐ Cada 2 años
- ☐ De forma ad hoc, ante cambios relevantes o incidentes
- ☐ Rara vez o nunca

## 2.3 ¿Qué grado de participación tiene la Alta Dirección en la revisión de los riesgos de ciberseguridad?

- ☐ Aprueba formalmente el mapa de riesgos y las prioridades de inversión
- ☐ Recibe informes periódicos, pero no participa en las decisiones
- ☐ Participación ocasional, ante incidentes graves
- ☐ Prácticamente nula

## 3. Adopción de FAIR y cuantificación económica del riesgo

### 3.1 ¿Utiliza su organización la metodología FAIR (Factor Analysis of Information Risk) o una metodología similar de cuantificación económica del riesgo de ciberseguridad?

- ☐ Sí, FAIR de forma explícita
- ☐ Sí, metodología propia pero basada en cuantificación económica
- ☐ Estamos en fase piloto / prueba de concepto
- ☐ No, pero lo estamos considerando
- ☐ No, y no está en nuestra agenda (todavía)

### 3.2 En caso de utilizar FAIR o metodología similar, ¿en qué ámbitos se aplica principalmente?

- ☐ Priorización de inversiones en controles de seguridad
- ☐ Justificación de presupuesto ante la Alta Dirección
- ☐ Toma de decisiones sobre seguros cibernéticos
- ☐ Evaluación de riesgos en proyectos y nuevas iniciativas
- ☐ Análisis post-incidente para estimar pérdidas reales
- ☐ Otro (especifique): \_\_\_\_
- ☐ No aplicable / No utilizamos cuantificación

### 3.3 ¿Qué grado de madurez considera que tiene su organización en la cuantificación económica del riesgo de ciberseguridad?

- ☐ Muy alto: usamos modelos cuantitativos de forma sistemática y auditables
- ☐ Alto: utilizamos modelos cuantitativos en la mayoría de decisiones relevantes
- ☐ Medio: combinamos cuantificación con enfoques cualitativos
- ☐ Bajo: predomina la matriz de calor y la valoración subjetiva
- ☐ Muy bajo: apenas cuantificamos más allá de estimaciones groseras

### 3.4 ¿Con qué herramientas realiza los análisis cuantitativos de riesgo?

- ☐ Hojas de cálculo (Excel, similares) con modelos FAIR

- ☐ Herramientas específicas de cuantificación de riesgos
- ☐ Herramientas GRC con módulos de análisis cuantitativo
- ☐ Desarrollo interno a medida
- ☐ No utilizamos herramientas específicas

## 4. Modelado de amenazas y uso de STRIDE

4.1 ¿Dispone la organización de un enfoque sistemático de modelado de amenazas para sistemas y servicios clave?

- ☐ Sí, a nivel corporativo, con metodología definida y plantillas
- ☐ Sí, pero limitado a determinados proyectos o áreas
- ☐ En fase piloto / exploración
- ☐ No, pero nos lo estamos planteando
- ☐ No, y no lo consideramos prioritario

4.2 ¿Con qué metodologías de modelado de amenazas trabaja habitualmente su organización?

- ☐ STRIDE
- ☐ PASTA
- ☐ LINDDUN / LINDDUN GO
- ☐ OCTAVE / EBIOS u otros marcos formales
- ☐ Metodología interna no alineada con marcos estándar
- ☐ No se aplica modelado de amenazas de forma formal

4.3 En caso de usar STRIDE, ¿en qué fases del ciclo de vida de los sistemas se aplica?

- ☐ Diseño de nuevas aplicaciones o servicios
- ☐ Revisión de arquitecturas existentes
- ☐ Evaluaciones previas a grandes cambios o migraciones (por ejemplo, a la nube)
- ☐ Análisis post-incidente
- ☐ Auditorías internas o externas
- ☐ No usamos STRIDE

4.4 ¿Integra su organización los resultados de STRIDE con la cuantificación económica de riesgos (por ejemplo, FAIR) para priorizar controles?

- ☐ Sí, de forma sistemática, cada amenaza STRIDE se traduce en escenarios cuantificados
- ☐ Sí, ocasionalmente, en proyectos o sistemas críticos
- ☐ No, pero nos gustaría avanzar en esa dirección
- ☐ No, y actualmente no lo contemplamos

4.5 ¿Hasta qué punto disponen de catálogos o bibliotecas internas de escenarios de amenazas basados en STRIDE reutilizables en distintos proyectos?

- ☐ Amplios catálogos corporativos mantenidos y versionados
- ☐ Catálogos parciales por áreas o equipos
- ☐ Listas informales, no estructuradas
- ☐ No disponemos de catálogos de escenarios

## 5. Indicadores FAIR-STRIDE por propiedades de seguridad

### 5.1 Autenticidad (suplantación de identidad)

5.1.1 ¿Mide su organización la tasa de incidentes de suplantación de identidad (por ejemplo, cuentas comprometidas, fraudes por phishing, ataques BEC) de forma periódica?

- ☐ Sí, con métricas formales y series históricas
- ☐ Sí, pero de forma ad hoc
- ☐ No, aunque disponemos de algunos datos dispersos
- ☐ No, y no tenemos visibilidad suficiente

5.1.2 ¿Cómo se cuantifica el impacto económico de los incidentes de suplantación de identidad?

- ☐ Estimamos pérdidas financieras directas por caso
- ☐ Incluimos costes de respuesta, investigación y remediación
- ☐ Consideramos impactos regulatorios (multas, sanciones)
- ☐ Evaluamos impactos reputacionales (pérdida de clientes, imagen)
- ☐ No se cuantifican de forma estructurada

5.1.3 ¿Dispone la organización de objetivos cuantitativos (KPIs) respecto a la reducción de incidentes de autenticidad comprometida?

- ☐ Sí, con objetivos anuales explícitos
- ☐ Sí, pero sólo a nivel de proyectos o unidades concretas
- ☐ No, pero se está trabajando en definirlos
- ☐ No, y no se consideran objetivos prioritarios

### 5.2 Integridad

5.2.1 ¿Qué grado de monitoreo y registro existe sobre la integridad de datos críticos (financieros, clínicos, operativos, etc.)?

- ☐ Controles robustos con registros detallados y revisiones periódicas
- ☐ Controles básicos con revisiones ocasionales
- ☐ Controles limitados y poco sistemáticos
- ☐ Prácticamente inexistentes

5.2.2 ¿Se cuantifican económicamente los posibles impactos derivados de alteraciones de integridad (datos erróneos en procesos clave, decisiones incorrectas, sanciones regulatorias)?

- ☐ Sí, con modelos cuantitativos formales (FAIR u otros)
- ☐ Sí, pero principalmente mediante estimaciones cualitativas
- ☐ No, aunque reconocemos que el impacto podría ser significativo
- ☐ No, y apenas se consideran estos escenarios

5.2.3 ¿Dispone su organización de indicadores de tiempo medio de detección y corrección de alteraciones de integridad relevantes?

- ☐ Sí, medidos y reportados periódicamente
- ☐ Algunos indicadores parciales

- ☐ Sin indicadores, sólo casos anecdóticos
- ☐ No se mide

### 5.3 No repudio

5.3.1 ¿Cuenta su organización con mecanismos técnicos y procedimentales que soporten el no repudio (por ejemplo, firmas electrónicas avanzadas, registros inalterables, evidencias forenses)?

- ☐ Sí, ampliamente desplegados en procesos clave
- ☐ Sí, pero sólo en procesos concretos
- ☐ Limitados o en fase piloto
- ☐ Prácticamente inexistentes

5.3.2 ¿Se han cuantificado posibles impactos económicos de disputas, fraudes o litigios debidos a ausencia de no repudio adecuado?

- ☐ Sí, como parte de análisis de riesgo formales
- ☐ De forma aproximada, caso por caso
- ☐ No, aunque se considera un riesgo relevante
- ☐ No se ha considerado

5.3.3 ¿Se utilizan los registros de no repudio como insumo en los modelos de riesgo para estimar probabilidad y magnitud de pérdidas?

- ☐ Sí, de forma sistemática
- ☐ Sí, pero sólo en algunos ámbitos
- ☐ No, aunque sería técnicamente posible
- ☐ No, y los registros se usan solo con fines operativos o legales

### 5.4 Confidencialidad

5.4.1 ¿Cómo se gestionan y miden los incidentes de confidencialidad (violaciones de datos, fugas de información, accesos indebidos)?

- ☐ Registro estructurado con estimación de volumen de datos y personas afectadas
- ☐ Registro básico sin detalle completo
- ☐ Sólo se registran los incidentes más graves
- ☐ No existe un registro organizado

5.4.2 ¿Se realiza cuantificación económica de los incidentes de confidencialidad, incluyendo impactos regulatorios y reputacionales?

- ☐ Sí, con modelos cuantitativos formales
- ☐ Sí, de forma aproximada, apoyada en casos previos
- ☐ No de forma sistemática, sólo en incidentes singulares
- ☐ No se cuantifican

5.4.3 ¿Qué grado de alineamiento existe entre la clasificación de la información y las prioridades de inversión en controles de confidencialidad (cifrado, DLP, controles de acceso, etc.)?

- ☐ Elevado: las decisiones de inversión siguen directamente la clasificación
- ☐ Medio: la clasificación influye pero no determina

- ☐ Bajo: se invierte más por percepción que por clasificación
- ☐ No se dispone de clasificación formal de la información

## 5.5 Disponibilidad

5.5.1 ¿Dispone la organización de métricas estructuradas sobre disponibilidad de sistemas críticos (SLAs, tiempos de inactividad, usuarios afectados)?

- ☐ Sí, ampliamente desplegadas y monitorizadas en tiempo real
- ☐ Sí, pero sólo para algunos sistemas o servicios
- ☐ Indicadores parciales, no consolidados
- ☐ No existen métricas formales

5.5.2 ¿Cómo se cuantifica el impacto económico de interrupciones de servicios críticos (por ciberataques, fallos tecnológicos o causas externas)?

- ☐ Cálculo sistemático de coste por hora de caída y pérdidas asociadas
- ☐ Estimaciones aproximadas en base a incidentes pasados
- ☐ Valoraciones ad hoc sin modelo estructurado
- ☐ No se cuantifica

5.5.3 ¿Se integran las métricas de disponibilidad con los planes de continuidad de negocio y recuperación ante desastres?

- ☐ Sí, con objetivos de RTO/RPO definidos y revisados
- ☐ Sí, pero de forma parcial o informal
- ☐ Planes de continuidad limitados y poco conectados a métricas
- ☐ No se dispone de planes de continuidad de negocio

## 5.6 Autorización (elevación y abuso de privilegios)

5.6.1 ¿Cómo se gestionan los accesos privilegiados y las elevaciones de privilegios en su organización?

- ☐ Solución PAM (Privileged Access Management) desplegada y operativa
- ☐ Controles manuales o parcialmente automatizados
- ☐ Controles básicos sin solución específica
- ☐ Gestión de privilegios muy limitada

5.6.2 ¿Dispone de métricas sobre intentos y éxitos de abuso de privilegios o accesos indebidos a información sensible?

- ☐ Sí, con indicadores periódicos y umbrales de alerta
- ☐ Sí, pero de forma parcial y sin umbrales claros
- ☐ Datos disponibles pero no consolidados en indicadores
- ☐ No disponemos de esta visibilidad

5.6.3 ¿Se cuantifican económicamente los escenarios asociados a abusos de privilegios (fraude interno, sabotaje, filtraciones, etc.)?

- ☐ Sí, mediante modelos cuantitativos (FAIR u otros)
- ☐ Sí, pero sólo en incidentes relevantes

- ☐ Rara vez, y sin modelo formal
- ☐ No se cuantifican

## 6. Zero Trust, segmentación y arquitectura de seguridad

6.1 ¿En qué grado ha adoptado su organización principios de arquitectura Zero Trust (verificación continua, mínimo privilegio, segmentación, etc.)?

- ☐ Alto: estrategia formal, hoja de ruta y despliegues en producción
- ☐ Medio: algunos proyectos clave aplican Zero Trust
- ☐ Bajo: iniciativas puntuales sin enfoque integral
- ☐ Nulo: modelo tradicional de perímetro confiable

6.2 ¿Se han modelado amenazas (por ejemplo, con STRIDE) y cuantificado riesgos (FAIR) para justificar inversiones en segmentación de red, microsegmentación o controles de acceso adaptativos?

- ☐ Sí, con análisis coste-beneficio cuantificados
- ☐ Sí, pero con análisis principalmente cualitativos
- ☐ No, aunque reconocemos que sería deseable
- ☐ No, y no está previsto

6.3 ¿Qué papel juegan los resultados de estos análisis en las decisiones de inversión en tecnologías de seguridad?

- ☐ Determinante: las decisiones se basan en reducción de pérdida esperada
- ☐ Importante, pero convive con otros factores (presión regulatoria, tendencias)
- ☐ Secundario: se usan para justificar decisiones ya tomadas
- ☐ Marginal o inexistente

## 7. Resiliencia, continuidad de negocio y seguros cibernéticos

7.1 ¿Dispone su organización de un programa formal de resiliencia y continuidad de negocio que integre ciberincidentes como escenarios clave?

- ☐ Sí, plenamente integrado
- ☐ Sí, pero con integración parcial de ciber
- ☐ Programas separados de TI, ciber y continuidad
- ☐ Programas incipientes o inexistentes

7.2 ¿Se utilizan modelos cuantitativos (FAIR o similares) para evaluar el beneficio económico de medidas de resiliencia (redundancia, backups avanzados, planes de crisis, etc.)?

- ☐ Sí, mediante análisis de reducción de pérdida esperada
- ☐ Sí, pero de forma puntual
- ☐ No, aunque sería deseable
- ☐ No se utilizan modelos cuantitativos

7.3 ¿Dispone la organización de seguro cibernético?

- ☐ Sí, con cobertura expresamente alineada a riesgos cuantificados
- ☐ Sí, pero contratado principalmente por requisitos externos

- ☐ No, pero se está considerando
- ☐ No, y no se considera relevante

7.4 En caso afirmativo, ¿utiliza la organización análisis cuantitativos para determinar los límites de cobertura y franquicias del seguro?

- ☐ Sí, con modelos específicos de estimación de pérdidas
- ☐ Parcialmente, apoyándonos en datos históricos
- ☐ No, se basa principalmente en negociación comercial
- ☐ No aplica / no disponemos de seguro cibernético

## 8. Datos, métricas y gobierno de la información de riesgo

8.1 ¿Existe un repositorio corporativo de incidentes de seguridad y datos asociados (costes, duraciones, impactos) utilizado para alimentar modelos de riesgo?

- ☐ Sí, centralizado y mantenido
- ☐ Sí, pero distribuido por áreas
- ☐ Información dispersa sin repositorio formal
- ☐ Prácticamente inexistente

8.2 ¿Qué grado de calidad y completitud considera que tienen sus datos de incidentes y costes asociados?

- ☐ Alto: datos completos y verificables
- ☐ Medio: lagunas ocasionales, pero aceptable
- ☐ Bajo: muchos datos ausentes o poco fiables
- ☐ Desconocido

8.3 ¿Quién es el responsable último del gobierno de los datos de riesgo de ciberseguridad?

- ☐ CISO / Seguridad de la Información
- ☐ Riesgos / Cumplimiento / Auditoría
- ☐ Finanzas / Control de gestión
- ☐ Tecnología / Operaciones
- ☐ No está claramente definido

## 9. Perspectiva normativa y regulatoria

9.1 ¿Con qué marcos normativos y regulatorios se alinea principalmente su organización en materia de ciberseguridad y resiliencia?

- ☐ ISO 27001 / 27002 / 27005
- ☐ NIST CSF / NIST RMF
- ☐ Normativas sectoriales (financieras, sanitarias, energía, etc.)
- ☐ NIS2 / DORA u otras directivas/reglamentos europeos
- ☐ Legislación nacional específica
- ☐ Otros (especifique): \_\_\_\_

9.2 ¿Hasta qué punto utiliza la organización las métricas FAIR-STRIDE para demostrar cumplimiento ante reguladores o auditores?



- ☐ De forma explícita, integradas en los informes
- ☐ De forma implícita, como base de argumentación
- ☐ Ocasionalmente, en casos concretos
- ☐ Prácticamente nada

9.3 ¿Con qué frecuencia se revisan y actualizan los modelos de riesgo y amenazas para alinearlos con cambios normativos o regulatorios?

- ☐ Al menos anual
- ☐ Cada 2-3 años
- ☐ Sólo ante cambios normativos significativos
- ☐ Rara vez o nunca

## 10. Cultura, talento y futuro de FAIR-STRIDE en la organización

10.1 ¿Dispone su organización de perfiles especializados en cuantificación de riesgos de ciberseguridad (FAIR o similares)?

- ☐ Sí, equipo dedicado
- ☐ Sí, personas específicas dentro de otros equipos
- ☐ Se apoya principalmente en terceros (consultoras, proveedores)
- ☐ No se dispone de este tipo de perfiles

10.2 ¿Qué nivel de comprensión de los modelos FAIR-STRIDE considera que tiene la Alta Dirección?

- ☐ Alto: comprenden conceptos clave y los utilizan en decisiones
- ☐ Medio: familiaridad general, pero sin uso sistemático
- ☐ Bajo: conocimiento superficial
- ☐ Muy bajo: es un lenguaje prácticamente ajeno

10.3 ¿Cuál es la intención de su organización respecto a la evolución de FAIR-STRIDE en los próximos 2-3 años?

- ☐ Profundizar y extender el uso a más áreas
- ☐ Mantener el nivel actual
- ☐ Explorar, pero sin compromisos formales
- ☐ Reducir o abandonar iniciativas de cuantificación

10.4 En una frase, ¿cómo describiría el principal obstáculo para avanzar en FAIR-STRIDE en su organización?

Respuesta abierta: \_\_\_\_\_